

Access control is a method of restricting access to sensitive data. Only those that have had their identity verified can access company data through an access control gateway.

What are the components of access control?

At a high level, access control is about restricting access to a resource. Any access control system, whether physical or logical, has five main components:

1. **Authentication:** The act of proving an assertion, such as the identity of a person or computer user. It might involve validating personal identity documents, verifying the authenticity of a website with a digital certificate, or checking login credentials against stored details.
2. **Authorization:** The function of specifying access rights or privileges to resources. For example, human resources staff are normally authorized to access employee records and this policy is usually formalized as access control rules in a computer system.
3. **Access:** Once authenticated and authorized, the person or computer can access the resource.
4. **Manage:** Managing an access control system includes adding and removing authentication and authorization of users or systems. Some systems will sync with G Suite or Azure Active Directory, streamlining the management process.
5. **Audit:** Frequently used as part of access control to enforce the principle of least privilege. Over time, users can end up with access they no longer need, e.g. when they change roles. Regular audits minimize this risk.

How does access control work?

Access control can be split into two groups designed to improve physical security or cybersecurity:

Physical access control: limits access to campuses, building and other physical assets, e.g. a proximity card to unlock a door.

Logical access control: limits access to computers, networks, files and other sensitive data, e.g. a username and password.

For example, an organization may employ an electronic control system that relies on user credentials, access card readers, intercom, auditing and reporting to track which employees have access and have accessed a restricted data center. This system may incorporate an access control panel that can restrict entry to individual rooms and buildings, as well as sound alarms, initiate lockdown procedures and prevent unauthorized access.

This access control system could authenticate the person's identity with biometrics and check if they are authorized by checking against an access control policy or with a key fob, password or personal identification number (PIN) entered on a keypad.

Another access control solution may employ multi factor authentication, an example of a defense in depth security system, where a person is required to know something (a password), be something (biometrics) and have something (a two-factor authentication code from smartphone mobile apps).

In general, access control software works by identifying an individual (or computer), verifying they are who they claim to be, authorizing they have the required access level and then storing their actions against a username, IP address or other audit system to help with digital forensics if needed.

Why is access control important?

Access control minimizes the risk of unauthorized access to physical and computer systems, forming a foundational part of information security, data security and network security.

Depending on your organization, access control may be a regulatory compliance requirement:

PCI DSS: Requirement 9 mandates organizations to restrict physical access to their buildings for onsite personnel, visitors and media, as well as having adequate logical access controls to mitigate the cybersecurity risk of malicious individuals stealing sensitive data. Requirement 10 requires organizations employ security solutions to track and monitor their systems in an auditable manner.

HIPAA: The HIPAA Security Rule requires Covered Entities and their business associates to prevent the unauthorized disclosure of protected health information (PHI), this includes the usage of physical and electronic access control.

SOC 2: The auditing procedure enforce third-party vendors and service providers to manage sensitive data to prevent data breaches, protecting employee and customer privacy. Companies who wish to gain SOC 2 assurance must use a form of access control with two-factor authentication and data encryption. SOC 2 assurance is particularly important for organization's who process personally identifiable information (PII).

ISO 27001: An information security standard that requires management systematically examine an organization's attack vectors and audits all cyber threats and vulnerabilities. It also requires a comprehensive set of risk mitigation or transfer protocols to ensure continuous information security and business continuity.

What are the types of access control?

The main types of access control are:

Attribute-based access control (ABAC): Access management systems where access is granted not on the rights of a user after authentication but based on attributes. The end user has to prove so-called claims about their attributes to the access control engine. An attribute-based access control policy specifies

which claims need to be satisfied to grant access to the resource. For example, the claim may be the user's age is older than 18 and any user who can prove this claim will be granted access. In ABAC, it's not always necessary to authenticate or identify the user, just that they have the attribute.

Discretionary access control (DAC): Access management where owners or administrators of the protected system, data or resource set the policies defining who or what is authorized to access the resource. These systems rely on administrators to limit the propagation of access rights. DAC systems are criticized for their lack of centralized control.

Mandatory access control (MAC): Access rights are regulated by a central authority based on multiple levels of security. MAC is common in government and military environments where classifications are assigned to system resources and the operating system or security kernel will grant or deny access based on the user's or the device's security clearance. It is difficult to manage but its use is justified when used to protect highly sensitive data.

Role-based access control (RBAC): In RBAC, an access system determines who can access a resource rather than an owner. RBAC is common in commercial and military systems, where multi-level security requirements may exist. RBAC differs from DAC in that DAC allows users to control access while in RBAC, access is controlled at the system level, outside of user control. RBAC can be distinguished from MAC primarily by the way it handles permissions. MAC controls read and write permissions based on a user/device's clearance level while RBAC controls collections of permissions that may include complex operations such as credit card transactions or may be as simple as read or write. Commonly, RBAC is used to restrict access based on business functions, e.g. engineers, human resources and marketing have access to different SaaS products. [Read our full guide on RBAC here.](#)

Rule-based access control: A security model where an administrator defines rules that govern access to the resource. These rules may be based on conditions, such as time of day and location. It's not uncommon to have some form of rule-based access control and role-based access control working together.